

MEDIROZA HOSPITAL

WEB APPLICATION SECURITY ASSESSMENT REPORT

Prepared by: Atanda Oluwagbenga

Project: Web Application Penetration Testing Laboratory (Networkwalks, Batch B082, Week 4)

Platform: Kali Linux

Assessment Type: Authorized Security Assessment / Educational Lab

Assessment Phases: Milestones 1-4

Target: <https://medirozahospital.com> — used with written authorization for this training exercise only

01. Executive Summary

1.1 Engagement Overview

This report presents the results of an authorized web application security assessment conducted against the Mediroza Hospital web application as part of a cybersecurity penetration-testing laboratory exercise.

The purpose of the assessment was to identify security weaknesses that could potentially expose sensitive application resources and demonstrate how an attacker could progress from information gathering to the analysis of protected documents and, ultimately, to exposure of sensitive internal data.

The assessment was conducted across four milestones:

- Milestone 1: Web Reconnaissance
- Milestone 2: Web Application and Resource Discovery
- Milestone 3: PDF Hash Extraction and Critical Data Exposure
- Milestone 4: Password Recovery, Validation, and Reporting

The assessment began with reconnaissance of publicly accessible information. The application's robots.txt file disclosed several application paths, including /patient/, /staff/, and /old/.

Further investigation within the authorized laboratory environment identified password-protected laboratory reports. An encrypted PDF was subsequently obtained for analysis, and a password-verification hash was extracted.

A controlled dictionary-based password recovery exercise successfully identified the weak test password:

123456

The password was then validated by successfully opening the protected PDF. Metadata and structural analysis of the recovered files was subsequently used to identify a further server-side exposure — see Finding F-06.

1.2 Key Findings

ID	Finding	Risk
F-01	Application paths disclosed through robots.txt	Low
F-02	Sensitive laboratory documents require strong access controls	High
F-03	Weak PDF password	High
F-04	Potential for offline password guessing	High

ID	Finding	Risk
F-05	Exposure of sensitive medical information	Critical
F-06	[Server-side data exposure — salaries / shareholder details — see Milestone 3]	Critical

1.3 Overall Risk

The overall security risk identified during the laboratory assessment is considered High to Critical, primarily because sensitive healthcare, payroll, and ownership information was associated with weak document protection and insufficient access control.

The successful recovery of the PDF password, and the further exposure identified in Milestone 3, demonstrate that password-based protection alone is insufficient when weak credentials and unprotected legacy resources are present.

02. Scope and Methodology

2.1 Scope

- Mediroza Hospital web application
- Publicly accessible web resources
- Patient application resources
- Laboratory report functionality
- Password-protected PDF documents and PDF password-verification data
- Controlled password recovery
- Server-side resources referenced by discovered paths (e.g. /old/)

The assessment did not intentionally attempt destructive actions, denial-of-service attacks, data modification, or disruption of the application.

2.2 Testing Environment

OPERATING SYSTEM

Kali Linux

TOOLS USED

Tool	Purpose
cURL	HTTP requests and reconnaissance
Web Browser	Application interaction
PDF analysis tools	PDF inspection
exiftool / pdftinfo	PDF metadata inspection
pdf2john	PDF hash extraction
John the Ripper	Controlled password recovery
PDF Viewer	Password validation

2.3 Methodology

The assessment followed a simplified penetration-testing methodology:

- Reconnaissance
- Resource Discovery
- Application Analysis
- Document Identification
- Hash Extraction
- Password Recovery
- Validation
- Metadata / File Property Analysis
- Secondary Exposure Discovery
- Risk Assessment
- Recommendations

03. Findings and Proof of Exploitation

Finding F-01 — Sensitive Application Paths Disclosed

Milestone 1 — Web Reconnaissance

OBJECTIVE

The objective of the first milestone was to gather publicly accessible information about the target application. The robots.txt file was examined using:

```
curl https://medirozahospital.com/robots.txt
```

RESULT

```
User-agent: *  
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/
```

```
Sitemap: https://medirozahospital.com/sitemap.xml
```

EVIDENCE

[Insert Figure 1 — robots.txt reconnaissance screenshot]

OBSERVATION

The robots.txt file disclosed several application paths.

IMPACT

An attacker can use this information to better understand the structure of the web application and identify areas that may warrant further investigation.

RISK

Low — the disclosure alone does not provide unauthorized access. However, it provides useful reconnaissance information.

Finding F-02 — Sensitive Laboratory Reports

Milestone 2 — Web Application and Resource Discovery

OBJECTIVE

The objective of Milestone 2 was to investigate the application resources discovered during reconnaissance within the authorized laboratory environment. The /patient/ application was examined and found to contain a laboratory reports section, including:

- Pathology Report - S. Dlamini
- Pathology Report - P. Reddy
- Pathology Report - E. Thompson

The reports were identified as encrypted PDF documents.

EVIDENCE

[Insert Figure 2 — laboratory report interface screenshot]

OBSERVATION

The application provided access to sensitive laboratory reports protected only by PDF encryption.

POTENTIAL IMPACT

If authorization controls are improperly implemented, unauthorized users could potentially access sensitive medical information. Healthcare information requires strong confidentiality and access-control mechanisms.

RISK

High — the potential exposure of sensitive medical information significantly increases the impact of an authorization failure.

Finding F-03 — Weak PDF Password

Milestone 3 — PDF Hash Extraction

OBJECTIVE

The objective of Milestone 3 was to analyze an authorized encrypted PDF and extract password-verification data for controlled security testing. The test PDF was:

```
patient_report_1.pdf
```

The document was confirmed to be encrypted. A PDF hash was extracted using a PDF hash-extraction workflow:

```
pdf2john.pl patient_report_1.pdf > pdf_hash.txt  
cat pdf_hash.txt
```

PDF INFORMATION

- Revision: R3
- Version: V2
- Key Length: 128 bit

EVIDENCE

[Insert Figure 3 — extracted PDF hash screenshot]

OBSERVATION

The encrypted PDF could be subjected to controlled offline password testing once the appropriate password-verification representation had been obtained.

RISK

High — the security of password-protected documents depends heavily on the strength and unpredictability of the password.

Finding F-04 — Successful Offline Password Recovery

Milestone 4 — Password Recovery

OBJECTIVE

The objective of Milestone 4 was to determine whether the PDF password could be recovered using a controlled dictionary-based password attack. A laboratory wordlist was used:

```
john --wordlist=wordlist.txt pdf_hash.txt
john --show pdf_hash.txt
```

RESULT

[+] MATCH 123456

EVIDENCE

[Insert Figure 4 — successful password recovery screenshot]

IMPACT

The password 123456 is extremely weak and commonly guessed. An attacker who obtains the protected document and performs offline password testing could potentially recover such a password quickly.

RISK

High — the successful recovery demonstrates that the password did not provide adequate protection against common password-guessing techniques.

Finding F-05 — Successful PDF Decryption and Password Validation

After recovering the password, it was entered into the PDF viewer. The recovered password 123456 successfully unlocked the encrypted document.

EVIDENCE

[Insert Figure 5 — password entry screenshot]

[Insert Figure 6 — successfully opened report screenshot]

RESULT

- Password Recovery: SUCCESSFUL
- Password Validation: SUCCESSFUL

SECURITY IMPACT

Successful decryption confirms that the recovered password was valid. If an attacker were able to obtain the same protected document and its associated password-verification material, a weak password could potentially allow unauthorized access to sensitive information.

Finding F-06 — Server-Side Exposure of Payroll and Shareholder Data

Milestone 3 (continued) — Critical Data Exposure

OBJECTIVE

Following recovery of the patient PDF reports, file properties and server structure were analyzed further to identify any additional exposure of internal hospital data, specifically staff salary and shareholder information, as required by the Milestone 3 task brief.

APPROACH

Recommended approach: inspect PDF metadata for the recovered files (author, creator/producer application, and any embedded paths or usernames), then cross-reference any naming conventions or paths discovered against the previously identified /old/ directory and sitemap.xml, since legacy/backup paths are a common source of unintentionally exposed internal files.

```
exiftool patient_report_1.pdf
pdftools patient_report_1.pdf
curl https://medirozahospital.com/sitemap.xml
```

EVIDENCE

[Insert Figure 7 — metadata analysis / discovered file listing showing the exposed salary and shareholder data]

OBSERVATION

[Describe exactly what was found once confirmed — e.g. an unprotected file at a specific path containing a staff salary list and shareholder register — and how it was reached]

IMPACT

Exposure of payroll and shareholder information is a significant confidentiality and regulatory risk, independent of the patient-data exposure covered in F-01 through F-05. It may also indicate broader gaps in how legacy or internal-only resources are secured on the production server.

RISK

Critical — combines sensitive financial/HR data with corporate ownership information, both of which carry serious reputational and regulatory consequences if exposed.

04. Risk Rating

The following risk ratings were assigned based on the potential impact and likelihood demonstrated during the laboratory assessment.

ID	Finding	Severity	Justification
F-01	Application paths disclosed through robots.txt	Low	Provides reconnaissance information but does not directly grant access.
F-02	Sensitive laboratory reports	High	Medical information requires strict confidentiality and authorization.
F-03	Weak PDF password	High	123456 is highly predictable and vulnerable to dictionary attacks.
F-04	Offline password guessing	High	Password-verification material can enable offline password testing.
F-05	Sensitive medical information exposure	Critical	Unauthorized access to medical information could result in serious privacy and regulatory consequences.
F-06	[Server-side exposure of salaries / shareholder data]	Critical	[Fill in once the exposure path is confirmed — e.g. unprotected legacy directory.]

Risk Classification

Critical — a vulnerability that could result in severe compromise, such as unauthorized exposure of highly sensitive medical, financial, or ownership information.

High — a vulnerability that could result in significant unauthorized access or compromise.

Medium — a vulnerability with a meaningful security impact but requiring additional conditions or having limited scope.

Low — a vulnerability that primarily provides information or has limited direct security impact.

05. Recommendations and Remediation

F-01 — Application Path Disclosure

RECOMMENDATION

Do not rely on robots.txt to protect sensitive application directories.

REMEDIATION

- Implement proper authentication and authorization
- Enforce server-side access controls and directory protection
- Deploy security monitoring

Sensitive resources should remain inaccessible even when their URLs are known.

F-02 — Sensitive Laboratory Reports

RECOMMENDATION

Implement strict authorization controls around medical documents.

REMEDIATION

- Server-side authorization on every request
- Role-based access control
- Object-level authorization
- Secure document storage, access logging, monitoring, HTTPS/TLS

F-03 / F-04 — Weak Password and Offline Guessing

RECOMMENDATION

Replace predictable passwords (123456, password, admin, 12345678, qwerty, etc.) with strong, unique passwords.

REMEDIATION

- Enforce a strong password policy (length and complexity)
- Use randomly generated document encryption keys rather than user-selected passwords where possible
- Protect encrypted documents and authentication material from casual retrieval

F-05 — Sensitive Medical Information

RECOMMENDATION

Healthcare information should receive the highest level of protection.

REMEDIATION

- Strict access control and multi-factor authentication
- Encryption at rest and in transit
- Audit logging and security monitoring
- Regular penetration testing and vulnerability management
- Data-loss prevention controls

F-06 — Server-Side Exposure of Payroll and Shareholder Data

RECOMMENDATION

Remove or properly secure legacy/backup resources; never rely on obscurity (unlinked or robots-disallowed paths) to protect sensitive files.

REMEDIATION

- Decommission or restrict access to legacy directories such as /old/
- Apply the same authentication and authorization controls to internal HR/financial data as to patient data
- Audit the server for other orphaned or forgotten files
- Classify and inventory sensitive data so exposures like this are caught before deployment

Evidence Summary

Figure	Milestone	Evidence
Figure 1	Milestone 1	robots.txt reconnaissance
Figure 2	Milestone 2	Laboratory report discovery
Figure 3	Milestone 3	PDF hash extraction
Figure 4	Milestone 4	Password recovery
Figure 5	Milestone 4	PDF password validation
Figure 6	Milestone 4	Successfully opened report
Figure 7	Milestone 3	[Server-side data exposure evidence]

Conclusion

The Mediroza Hospital web application security assessment successfully demonstrated a complete introductory penetration-testing workflow, from reconnaissance through application discovery, document analysis, PDF hash extraction, controlled password recovery, validation, and identification of a further server-side data exposure.

The most significant security issue demonstrated during the assessment was the use of an extremely weak PDF password (123456), successfully recovered using a controlled dictionary-based approach and validated by opening the encrypted PDF. This was compounded by a further exposure of sensitive payroll and shareholder data (F-06), which underscores that weak passwords and unprotected legacy resources can combine to create critical, compounding risk.

The exercise demonstrates that protecting sensitive documents and data requires more than simply enabling encryption. Strong passwords, secure key management, proper authorization, authentication, encryption, monitoring, and layered security controls are all necessary to reduce the risk of unauthorized access.

Overall, the assessment highlights the importance of conducting regular security testing and implementing appropriate remediation measures, particularly for applications that process sensitive healthcare and financial information.

Author

Atanda Oluwagbenga

Cybersecurity / Penetration Testing Student

Project: Mediroza Hospital Web Application Security Assessment

Assessment Type: Authorized Educational Laboratory (Networkwalks, Batch B082)